

The CIA Triad

CIA TRIAD



Integrity

(Data Accuracy & Trustworthiness)

- **Definition:** Safeguarding data from unauthorized modification, tampering, or deletion to ensure it remains reliable and correct.
- **Hashing (e.g., SHA-256):** Generating a unique digital fingerprint of a file; even a microscopic change in the data completely changes the hash, exposing tampering.
- **Digital Signatures:** Cryptographic proof that verifies the identity of the sender and guarantees the message was not altered in transit.
- **Backups:** Keeping clean, untouched copies of data to restore from if the live data becomes corrupted or modified by ransomware.

Availability

(Systems Up When Needed)

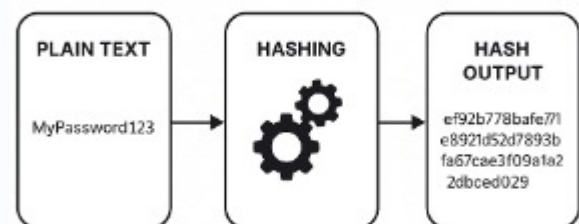
- **Definition:** Ensuring that authorized users have continuous, reliable access to data, networks, and systems whenever they require them.
- **Redundancy:** Setting up duplicate infrastructure (e.g., secondary servers or backup power supplies) so the system keeps running if the primary component fails.
- **RAID:** Combining multiple physical hard drives into a single logical unit to protect data and maintain uptime if one drive dies.
- **DDoS Mitigation:** Using traffic filtering and content delivery networks (CDNs) to absorb and block massive flood attacks meant to crash websites.
- **Regular Maintenance:** Performing scheduled software updates, hardware health checks, and performance tuning to prevent unexpected system downtime.

Confidentiality

(Authorized Access Only)

- **Definition:** Ensuring that sensitive data is only accessible to authorized individuals and processes while blocking unauthorized eyes.
- **Encryption:** Scrambling data into an unreadable format using a key, making it useless to attackers if intercepted.
- **MFA (Multi-Factor Authentication):** Requiring two or more distinct proofs of identity (e.g., password + SMS token) before granting access.
- **ACLs (Access Control Lists):** Internal system rules that explicitly define which users or groups are allowed to view specific files and folders.

SHA-256



How MFA Verifies User Identity



Step 1

Username and password entered



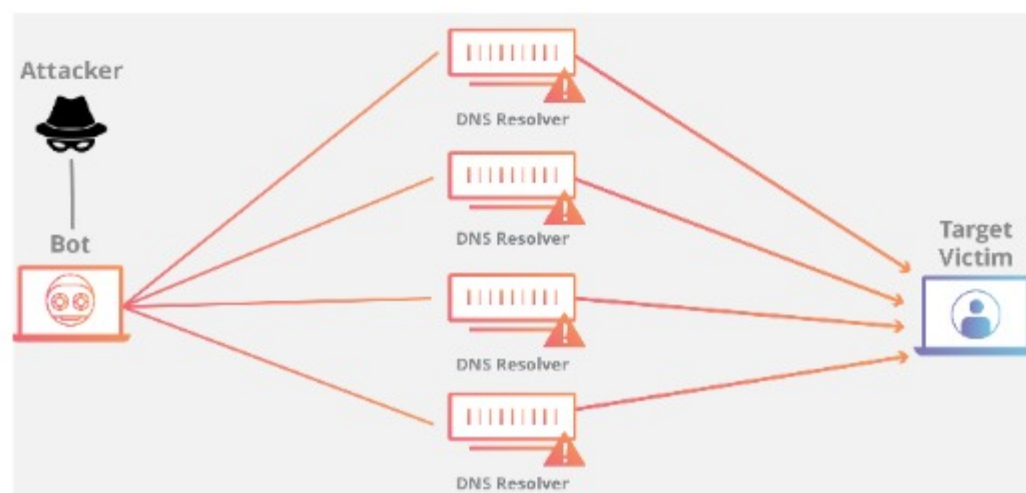
Step 2

Pin from mobile app entered



Step 3

Fingerprint verified



Vulnerability vs. Threat vs. Risk

Vulnerability (The Weakness)

Definition: A flaw, gap, or weakness in your security defenses, systems, or procedures that can be exploited.

Examples:

- **Technical:** An unpatched software bug or outdated operating system.
- **Physical:** An unlocked server room door or a lack of security cameras.
- **Human:** Employees who haven't been trained to recognize phishing emails.

Threat (The Danger)

Definition: Any potential event or actor with the capability and intent to exploit a vulnerability and cause harm.

Examples:

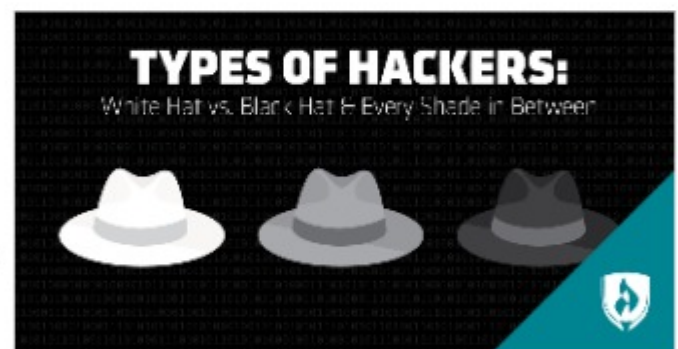
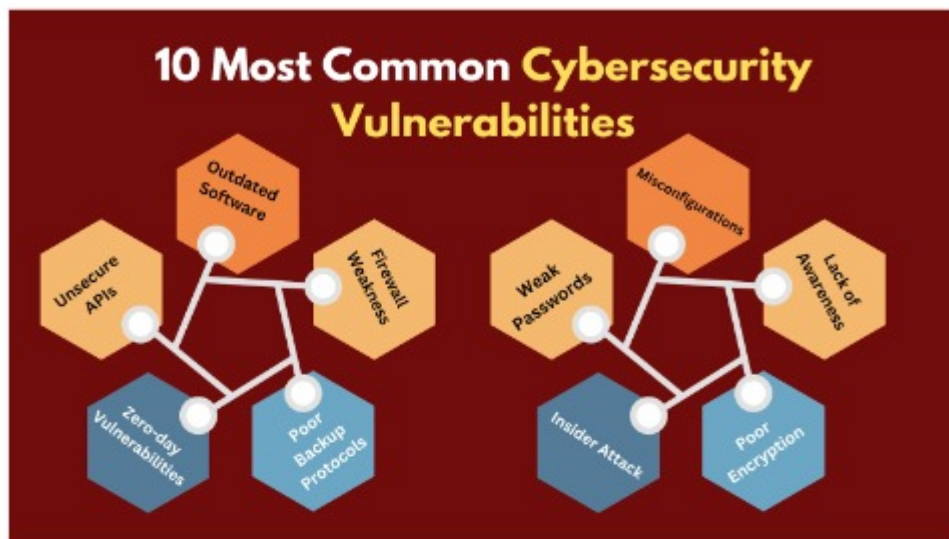
- **Malicious Actors:** Cybercriminals, state-sponsored hackers, or disgruntled insider employees.
- **Technical Threats:** Malware variants, automated botnets, and credential-stuffing tools.
- **Environmental/Natural:** Hurricanes, floods, fires, or power grid failures.

Risk (The Potential Damage)

Definition: The mathematical probability combined with the business impact of a threat successfully exploiting a vulnerability.

Examples:

- **Financial Loss:** The cost of ransom payments, legal fines, and system remediation.
- **Reputational Damage:** Loss of customer trust, negative media coverage, and brand devaluation.
- **Operational Disruption:** Total business downtime, inability to process payments, or loss of proprietary data.



Phishing

Common Cyber Attacks

(Social Engineering)

- **Definition:** Deceiving individuals into handing over sensitive information, typically via fraudulent communications that mimic trusted entities.
- **Mechanism:**
 - Sends spoofed emails, texts (Smishing), or voice calls (Vishing).
 - Uses high-pressure tactics (e.g., "Account suspended!") to force panic.
 - Directs victims to lookalike login pages to harvest credentials or session tokens.
- **Key Defense:** Security awareness training, Multi-Factor Authentication (MFA), and email authentication protocols (SPF, DKIM, DMARC).



Ransomware

(Extortion Malware)

- **Definition:** A sophisticated category of malicious software designed to lock users out of their data or systems until a ransom is paid.
- **Mechanism:**
 - Gains entry via phishing links, unpatched vulnerabilities, or compromised RDP (Remote Desktop Protocol) credentials.
 - Quietly maps the network, deletes local backups, and exfiltrates sensitive files.
 - Deploys strong cryptographic encryption across all accessible drives and displays a ransom note.
- **Key Defense:** Air-gapped/immutable backups, robust endpoint detection, and comprehensive patch management.

Malware

Definition: An umbrella term for any code or application explicitly written to compromise, damage, or exploit a device, service, or network.

Common Types:

- **Viruses & Worms:** Self-replicating code designed to spread across files or networks.
- **Spyware & Keyloggers:** Hidden software that tracks user activity, keystrokes, and browsing data.
- **Trojan Horses:** Malicious code disguised as legitimate software to trick users into running it.

Key Defense: Up-to-date Antivirus/EDR software, application whitelisting, and avoiding untrusted software downloads.



Types of Malware



Man-in-the-Middle (MitM)

Definition: An attack where a threat actor secretly intercepts, relays, and potentially alters the communication between two entities who believe they are talking directly to each other.

Mechanism:

- Set up via rogue Wi-Fi hotspots ("Evil Twins") or ARP spoofing on local networks.
- Forces the victim's traffic through the attacker's device.
- Strips away encryption (SSL/TLS stripping) to read passwords, session cookies, and financial data in plain text.

Key Defense: Enforcement of HTTPS, using a secure Virtual Private Network (VPN), and disabling automatic connections to open Wi-Fi.

MITM



SQL Injection (SQLi)

Definition: An injection attack that targets web applications by inserting malicious database commands into user input fields.

Mechanism:

- Finds a web form (like a login or search box) that lacks proper input validation.
- Submits raw SQL code (e.g., ' OR '1'='1) into the input field.
- Fools the backend database into bypassing authentication, revealing hidden records, or completely destroying tables.

Key Defense: Using parameterized queries (prepared statements), input sanitization, and web application firewalls (WAFs).

SQL Injection

